

**TEMPLATE
PROJECT WORK**

Corso di Studio	INFORMATICA PER LE AZIENDE DIGITALI (L-31)
Dimensione dell'elaborato	Minimo 6.000 – Massimo 10.000 parole (<i>pari a circa Minimo 12 – Massimo 20 pagine</i>)
Formato del file da caricare in piattaforma	PDF
Nome e Cognome	Micael Tuscano
Numero di matricola	0312300121
Tema n. (Indicare il numero del tema scelto):	2
Titolo del tema (Indicare il titolo del tema scelto):	Privacy e sicurezza aziendale
Traccia del PW n. (Indicare il numero della traccia scelta):	13
Titolo della traccia (Indicare il titolo della traccia scelta):	Sviluppo di un software mobile-friendly per il calcolo del fattore di rischio
Titolo dell'elaborato (Attribuire un titolo al proprio elaborato progettuale):	Rischio e sicurezza

PARTE PRIMA – DESCRIZIONE DEL PROCESSO

Utilizzo delle conoscenze e abilità derivate dal percorso di studio

(Descrivere quali conoscenze e abilità apprese durante il percorso di studio sono state utilizzate per la redazione dell'elaborato, facendo eventualmente riferimento agli insegnamenti che hanno contribuito a maturarle):

L'organizzazione e l'elaborazione di questo progetto sono il risultato dell'applicazione di nozioni e argomenti appresi nelle materie ed esami caratterizzanti nel corso L-31 (Informatica per aziende digitali):

- **Tecnologie Web:** Questo percorso mi ha fornito gli strumenti tecnici per la creazione del sito web usufruendo del linguaggio HTML5, CSS3 e JavaScript. Sono state applicate per creare la pagina di download, garantendo che fosse mobile-friendly e responsive. Oltretutto il corso mi ha permesso di aumentare il mio bagaglio di conoscenza potendolo applicare a molti progetti differenti e versatili per uso lavorativo e quotidiano.
- **Diritto per le aziende digitali:** Al secondo anno ho avuto il piacere di apprendere una materia fondamentale per la parte di analisi normativa del progetto.
Grazie a questo corso mi è stato possibile inquadrare tutte le normative riguardanti la sicurezza e la privacy aziendale, applicando e garantendo una conoscenza fondamentale per la stesura e approfondimento del

project work. Tra queste nozioni mi è stato molto utile l'argomento del GDPR e della responsabilità digitale.

- **Calcolo delle probabilità e statistica:** Questa materia del primo anno del mio corso di studi è stato la base di tutto questo progetto. Mi ha permesso di comprendere il significato dietro le formule riguardanti il project work, in particolare, il rischio direttamente proporzionale alla probabilità che un determinato evento capiti e alla magnitudo, ovvero alla gravità di un evento.
- **Programmazione 1 e 2:** Questi due esami, seppur in due anni differenti, sono stati importantissimi per il mio sviluppo studentesco, per la mia crescita personale nel programmare e nell'approccio con i linguaggi relativi. Ho potuto apprendere varianti di codici, librerie e di utilizzi vari, aprendomi le porte per iniziare a programmare in HTML.
- **Reti di calcolatori e Cybersecurity:** Tra tutte le materie che ho avuto a cui ho avuto il piacere di prendere parte è stata proprio Reti di calcolatori e Cybersecurity, proprio perché oltre a un interesse personale è stato perfetto per garantire la riuscita di questo progetto, per darmi concetti e risorse come i concetti di sicurezza e crittografia, fondamentali per intraprendere un percorso progettuale riguardante il calcolo del fattore di rischio.

Fasi di lavoro e relativi tempi di implementazione per la predisposizione dell'elaborato
(Descrivere le attività svolte in corrispondenza di ciascuna fase di redazione dell'elaborato. Indicare il tempo dedicato alla realizzazione di ciascuna fase, le difficoltà incontrate e come sono state superate):

Prima fase: Analisi per le informazioni per la creazione della parte teorica del progetto.

Per questa fase ho utilizzato circa una settimana.

- Attività: Studio e ricerca costante di libri o siti affidabili da cui prendere le informazioni necessarie per la stesura della parte teorica del progetto.

Mi sono servito di video provenienti da YouTube riguardanti l'argomento principale così da essere il più preparato possibile a completare tale fase. Inoltre mi è stato utile ripassare e ristudiare certi argomenti provenienti da materie utilizzate nel mio percorso universitario suddivisi nei 3 anni di studio. L'obiettivo era ovviamente poter avere le giuste conoscenze, per poter conoscere al meglio le nozioni base e specifiche per scrivere il fondamento di questo project work.

Seconda fase: Durante la prima settimana, dopo aver colto e appreso varie informazioni riguardanti l'argomento, mi sono cimentato nella stesura dello scheletro principale di tale progetto.

- Attività: Elaborazione del documento esplicativo che funge da cuore teorico del progetto. Post ricerca, mi sono imbattuto nel dover scrivere e trovare le parole adatte per poter spiegare al meglio (in maniera accademica, ma comprensibile) tale contenuto. Sicuramente ci sono state tante difficoltà a trovare i discorsi e il lessico giusto, ma sapendo approfonditamente l'argomento sono riuscito a spiegarlo nel modo più chiaro possibile, così qualunque persona visiti il sito e il PDF, possa comprendere affondo i rischi e i problemi che spesso portano a difficoltà a livello, non solo aziendale, ma anche quotidiano.

Terza fase: La seconda settimana, dopo aver ricercato e scritto lo scheletro del progetto, era il momento di iniziare la fase di programmazione web in HTML.

- Attività: Durante la stesura dei codici HTML e CSS ho sostenuto l'esame di Tecnologie Web; questo mi ha aiutato a studiare di pari passo tutte le librerie utili per svolgere il lavoro al meglio. Il problema principale è stato la quantità di tempo che da me impiegato a scrivere il codice e a spiegarlo in modo chiaro e conciso.

Quarta fase: Dopo lo studio approfondito, la stesura del cuore del testo, la programmazione del sito web, sono arrivato alla fine della seconda settimana con le prove riguardanti il funzionamento del web.

- Attività: Controllo e prove riguardanti il sito web, il QR Code e la visualizzazione su dispositivi mobili come cellulare. La difficoltà riscontrata anche in questo caso è stato lo studio più approfondito dei codici e l'accessibilità a tale sito. Ha richiesto infatti un'attenzione specifica per alcune parti fondamentali come il collegamento al PDF.

Quinta fase: Questa è stata l'ultima fase che mi ha permesso di concludere il mio progetto l'ultima settimana.

- Attività: Durante l'ultima settimana ho reso il testo esaustivo e ben spiegato, creando un contorno al cuore principale. Arrivando a produrre una spiegazione di poco più di 6000 parole, obiettivo che ha richiesto

particolare attenzione, ma con la giusta preparazione e bibliografia sono riuscito a completare senza troppi problemi.

Risorse e strumenti impiegati

(Descrivere quali risorse - bibliografia, banche dati, ecc. - e strumenti - software, modelli teorici, ecc. - sono stati individuati ed utilizzati per la redazione dell'elaborato. Descrivere, inoltre, i motivi che hanno orientato la scelta delle risorse e degli strumenti, la modalità di individuazione e reperimento delle risorse e degli strumenti, le eventuali difficoltà affrontate nell'individuazione e nell'utilizzo di risorse e strumenti ed il modo in cui sono state superate):

Per poter redigere l'elaborato sono state utilizzate diverse risorse teoriche e digitali, utilizzate con l'obiettivo di garantire un approccio completo e chiaro con il contesto della gestione del rischio a livello informatico.

Dal punto di vista delle risorse bibliografiche e informative, la ricerca ha avuto spunto principalmente da siti web specializzati nel campo della cybersicurezza e della valutazione del rischio, tra cui piattaforme istituzionali come IBM, ACN e altri portali molto affidabili. Queste fonti sono state scelte perché affidabili, costantemente aggiornate e in grado di dare una visione oggettiva, tecnica del rischio informatico. In maniera più centrata sono stati fondamentali certi concetti come la relazione tra probabilità, impatto e i principali tipi di minacce informatiche.

Un ruolo centrale è stato applicato ai modelli teorici di valutazione del rischio, in particolare il modello secondo cui il rischio sia proporzionale tra probabilità e entità di danno. Seguito dalla seguente formula sottostante:

$$R = P \times M$$

Inoltre sono state utilizzate tabelle qualitative di probabilità e gravità di minaccia, che hanno permesso di classificare il rischio in modo semplice ma efficace, rendendo il modello comprensibile anche a utenti non esperti. Questa scelta è stata necessaria per creare uno strumento pratico e applicabile anche in contesti reali, come aziende o ambienti scolastici.

Per quanto riguarda gli strumenti, sono stati utilizzati:

- Utilizzo di strumenti concettuali, riguardo la matrice del rischio, usato per la valutazione e visualizzazione del rischio.
- Strumenti digitali e software, come Visual Studio Code e GitHub.
- Utilizzo di contenuti multimediali per lo studio e l'apprendimento di informazioni utili per lo svolgimento dell'elaborato, sia da parte pratica che teorica.

Sito web: <https://micaeltuscano-source.github.io/PW--valutazione-rischio/>

La ricerca si è basata su ricerche mirate online, selezionando contenuti pertinenti e confrontando più fonti per garantire l'accuratezza delle informazioni. In alcuni casi la difficoltà principale è stata distinguere tra fonti affidabili e contenuti superficiali o non aggiornati. Questo problema è stato superato privilegiando siti istituzionali, articoli tecnici e contenuti con un approccio molto chiaro. Un'altra problematica importante è stata tradurre concetti teorici complessi in un linguaggio semplice, anche per quanto riguarda lo scheletro di questo progetto. Questo è stato poi risolto utilizzando esempi pratici, tabelle e schemi riassuntivi, rendendo il contenuto più accessibile.

Infine l'uso combinato di risorse teoriche e strumenti pratici ha permesso di sviluppare un elaborato equilibrato in cui il concetto di rischio non viene solo descritto, ma anche applicato in modo concreto e specifico, mostrando con rilevata importanza la consapevolezza della gestione del rischio, soprattutto in ambito informatico, dove una grande percentuale di incedenti e pericoli sono legati al fattore umano.

BIBLIOGRAFIA E SITOGRAFIA

Libri:

- Anderson, R. (2020). *Security Engineering: A Guide to Building Dependable Distributed Systems* (3rd ed.). Wiley.
- Stallings, W. (2018). *Network Security Essentials: Applications and Standards* (6th ed.). Pearson.

- Whitman, M. E., & Mattord, H. J. (2019). *Principles of Information Security* (6th ed.). Cengage Learning.
- Hubbard, D. W. (2009). *The Failure of Risk Management: Why It's Broken and How to Fix It*. Wiley.

Articoli e documentazione:

- Kaplan, S., & Garrick, B. J. (1981). On the quantitative definition of risk. *Risk Analysis*, 1(1), 11–27.
- International Organization for Standardization. (2018). *ISO 31000: Risk Management Guidelines*.
- International Organization for Standardization / International Electrotechnical Commission. (2022). *ISO/IEC 27001: Information Security Management Systems Requirements*.
- International Organization for Standardization / International Electrotechnical Commission. (2018). *ISO/IEC 27005: Information Security Risk Management*.
- National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity (NIST CSF)*.

Sitografia:

- OWASP Foundation. *OWASP Top 10 – Web Application Security Risks*. <https://owasp.org>
- European Union Agency for Cybersecurity (ENISA). *Threat Landscape Report*. <https://www.enisa.europa.eu>
- National Vulnerability Database (NVD). *CVE and Vulnerability Data Repository*. <https://nvd.nist.gov>
- Common Vulnerability Scoring System (CVSS). *CVSS v3.1 Specification Document*. <https://www.first.org/cvss>
- Agenzia per la Cybersecurity Nazionale (ACN). *Gestione degli eventi, minacce e incidenti cyber*. <https://www.acn.gov.it>
- IBM Security. *Cybersecurity Risk Assessment Overview, Types of Cyber Threats and Attack Vectors*. <https://www.ibm.com/security>
- Check Point Research. *Cyber Attack Trends and Threat Intelligence Report*. <https://www.checkpoint.com>
- SentinelOne. *Cybersecurity Breaches and Incident Response Analysis*. <https://www.sentinelone.com>
- Cybersecurity360. *Gestione del rischio informatico: strategie e best practice*. <https://www.cybersecurity360.it>
- SGSL Web. *Sistemi di gestione della sicurezza e valutazione del rischio*. <https://www.sgsweb.it>
- Ecloga Italia. *Modelli matriciali per la valutazione del rischio*. <https://www.eclogaitalia.it>

PARTE SECONDA – PREDISPOSIZIONE DELL'ELABORATO

Obiettivi del progetto

(Descrivere gli obiettivi raggiunti dall'elaborato, indicando in che modo esso risponde a quanto richiesto dalla traccia):

L'obiettivo principale del progetto è stato quello di trasformare il concetto teorico di calcolo di rischio in uno strumento, facilmente accessibile e utilizzabile, superando la difficoltà principale legata alla complessità delle normative e dei metodi di valutazione.

A differenza di un atteggiamento solo teorico, il progetto si è orientato a rendere il rischio accessibile e comprensibile, utilizzando tabelle di probabilità e pericolosità. Questo ha permesso di evitare calcoli complessi e di fornire un sistema semplice per contare il rischio in base alla gravità e alla probabilità degli eventi.

Un obiettivo importante raggiunto è stato quello di semplificare l'accesso alle informazioni: il contenuto teorico è stato organizzato con chiarezza, pensato per essere consultato rapidamente da qualsiasi tipo di persona. In questo modo si risponde direttamente alla richiesta della traccia di creare una guida esplicativa.

Dal punto di vista applicativo, il progetto risponde agli obiettivi richiesti attraverso:

- La creazione di una pagina web essenziale, che non complica l'esperienza e lo studio della piattaforma, ma permette direttamente il download del documento;
- L'uso del QR Code, che elimina il problema dell'accesso da mobile e rende il sistema immediato;
- Compatibilità tra dispositivi, dato che il contenuto è fruibile sia da PC che da dispositivi mobili.

Un altro obiettivo raggiunto è quello di collegare il rischio informatico alla realtà concreta e applicabile tutti i giorni, notando che non dipende solo da attacchi esterni ma anche da comportamenti errati degli utenti fisici. Questo rende il progetto non solo tecnico, ma anche utile per aumentare la consapevolezza alle persone reali.

Contestualizzazione

(Descrivere il contesto teorico e quello applicativo dell'elaborato realizzato):

Il contesto del progetto è attuato nella società digitale, in cui l'uso continuo, diffuso e quotidiano delle tecnologie informatiche espone continuamente dati, sistemi e persone a rischi di qualunque tipo. In particolare il progetto si concentra sull'ambito della sicurezza informatica, dove il rischio non è legato solo a fattori tecnici, ma anche al comportamento umano e dell'azienda. Dal punto di vista teorico, l'elaborato si concentra sull'idea del rischio come grandezza misurabile e calcolabile attraverso elementi o parametri ben definiti, come probabilità che un evento si verifichi e la gravità delle situazioni. Questo viene accostato a modelli di valutazione di rischio utilizzati anche nei DVR (documenti di valutazione dei rischi), dove il rischio viene classificato attraverso scale, matrici e per prendere o supportare decisioni risolutive.

Un aspetto notevole nel contesto teorico è che il rischio informatico non si centra solo sugli attacchi esterni (come virus o attacchi hacker), ma anche fattori interni. Sovente il problema deriva dagli umani stessi. Questo introduce una visione più ampia del rischio, che coinvolge competenze, comportamenti e consapevolezza degli utenti.

Dal punto di vista applicativo, l'elaborato entra in un contesto pratico in cui è necessario disporre di strumenti semplici per valutare il livello di rischio. Per questo motivo viene progettato un sito in cui si possa scaricare in modo rapido e veloce questa guida, per valutare rapidamente il livello di rischio e porre rimedio.

Il progetto è quindi pensato per essere utilizzato in situazioni reali, come l'analisi di sicurezza in ambienti informatici, valutazioni rapide durante attività lavorative o scolastiche, oppure trarre conoscenza e informazioni per altre decisioni in contesti organizzativi.

Descrizione dei principali aspetti progettuali

(Sviluppare l'elaborato richiesto dalla traccia prescelta):

Introduzione generale al concetto di rischio

Nell'attuale società moderna, caratterizzato da costante digitalizzazione, globalizzazione dei processi digitali e difficoltà crescenti delle reti, il rischio è diventato un punto centrale e fondamentale di quasi ogni scelta aziendale, pubblica e professionale. Non è più solo un'idea ininfluyente di un possibile e innocente problema, ma un elemento perno dei processi decisionali, che influenza investimenti, progetti, gestione delle risorse e prudenza informatica.

Generalizzando, il rischio può essere descritto come la probabilità che un evento futuro incerto produca effetti negativi su un sistema, riducendone l'efficienza, compromettendo l'utilizzo, il funzionamento o creando danni di economici, giuridici o personali.

Questo mostra due aspetti:

1. **Incertezza** = Non sappiamo quando l'evento accadrà.
2. **La conseguenza negativa** = L'impatto che accade davvero

Tuttavia, il rischio contiene anche una componente positiva, se ben gestita: un'azienda che accetta intenzionalmente e consapevolmente alcuni rischi può trarne vantaggi di tipo competitivo, d'innovazione o di crescita, se dispone di strumenti adeguati a considerare e controllare l'entità delle esposizioni. Il rischio in questo caso non è solo una minaccia, ma è un parametro che si bilancia tra tolleranza, interesse per il rischio e capacità di adattarsi.

Nel contesto delle tecnologie riguardo l'informazione, l'introduzione delle evoluzioni digitali ha amplificato in modo esponenziale la necessità di gestire il rischio. Sistemi interconnessi, cloud, IoT, automazione industriale, smart working, open-API e piattaforme varie hanno aumentato la superficie di attacco, moltiplicando il numero di asset sensibili e di possibili punti di ingresso vulnerabili per minacce esterne e problemi interni. In concomitanza con questo, le organizzazioni non possono più limitarsi a reazioni superflue o ad approcci leggeri, ma hanno bisogno attrezzature e sistemi utili, misurabili, replicabili e tracciabili, in grado di poter individuare e calcolare il rischio, segnalarne l'evoluzione e guidare verso contromisure.

Proprio in questo da questo nasce l'idea di un sito web con contenuto scaricabile, inteso sia come supporto alla gestione del rischio generale sia come applicativo specifico per la cybersecurity. L'obiettivo è far comprendere e rendere accessibile da qualsiasi dispositivo mobile o desktop, il file che permetta a non esperti di:

- **Identificare** probabilità, impatto, vulnerabilità, esposizione, ecc.
- **Calcolare** un fattore di rischio secondo modelli, tabelle, consolidate o avanzate.
- **Interpretare** il risultato tramite matrici, soglie, classificazioni o dashboard semplici.

Questo infatti è un ponte tra teoria, pratica e experience, pensato per essere usato sul campo, durante ispezioni, analisi di processo o meeting di team di sicurezza, per poter rendersi conto il calcolo di rischio e i modi per poter evitare problematiche di vario tipo.

Fondamenti teorici della valutazione del rischio

La valutazione del rischio è un campo consolidato nel campo universitario e normativo, con basi in discipline come ingegneria, finanza, gestione della sicurezza, medicina e informatica. I modelli di base, pur apparendo semplici, costituiscono la base per la maggior parte degli strumenti utilizzati in ambito industriale, sanitario e digitale.

Il modello più diffuso definisce il rischio come prodotto tra probabilità e danno:

$$R = P \times M$$

Rischio = Probabilità × Danno (magnitudo)

Immagine presa dal link

<https://www.youtube.com/watch?v=WqiXGwaL9m4>

Dove:
R è il rischio
P è la probabilità che capiti un evento
M è la Magnitudo

Dove:

- **R** è il livello di rischio.
- **P** è la probabilità che l'evento si verifichi.
- **D** è il danno o la magnitudo dell'evento, espresso in basso, medio, alto o costo, ore di "downtime", quantità di dati persi, etc.

Questa formula è alla base di molte metodologie di sicurezza sul lavoro, gestione della salute e cybersecurity. In ambito della cybersecurity infatti, la P può rappresentare la probabilità che una vulnerabilità venga sfruttata da un aggressore, mentre la D può essere considerata in costi di recupero, multe o problemi a livello intimo/personale.

La sua qualità principale è la semplicità e la trasparenza, perché è facile da spiegare a chi non ha competenze nel settore e permette di confrontare rapidamente scenari diversi. Però è limitato perché la relazione lineare tra probabilità e impatto (in molti casi reali) sottovaluta eventi rari ma estremi (perdite catastrofiche, breach su larga scala, interruzioni di servizio importanti).

Evoluzione storica del concetto di rischio

Il concetto di rischio ha subito una grande evoluzione nel corso della storia, mostrando i cambiamenti culturali, scientifici ed economici della società.

Nelle società antiche il rischio era solo visto e valutato attraverso ambienti religiosi o mitologici. Gli eventi nefasti o eventi di presagio, venivano attribuiti a divinità o eventi naturali per sfortune. Infatti il rischio non era sotto un'analisi razionale né di misurazione, ma veniva accettato come parte della natura e vita quotidiana, inevitabile e ineluttabile.

Con l'inizio dello sviluppo del ragionamento moderno, tra il **1600 e il 1700**, si assistette a una trasformazione importantissima, ovvero con la nascita della teoria della probabilità, grazie ai contributi di matematici come Pascal e de Fermat, consentì per la prima volta nella storia di rappresentare l'incertezza in modo matematico. Questo rappresenta un punto di cambiamento fondamentale, perché il rischio diventa misurabile e quindi gestibile.

Nel 1800, con la rivoluzione industriale, la definizione di rischio si amplifica ancora. L'arrivo di macchinari complessi, infrastrutture di produzione e processi industriali su larga scala produce nuovi tipi di pericolo, non più legate solo alla natura ma anche ai sistemi artificiali creati dall'uomo. In questo momento storico si attuano le prime forme di sicurezza e di gestione sistematica del rischio nelle industrie.

Nel 1900, avvenne l'evoluzione della teoria dei sistemi, della cibernetica e delle decisioni contribuisce aiuta a poter identificare in modo più sofisticato il rischio. Questo infatti non viene più visto e valutato come un evento isolato, ma come una parte dei grandi sistemi dinamici complessi. Inizia a crescere l'idea che il rischio non possa essere debellato, ma soltanto controllato e governato attraverso strategie di ottimizzazione.

Negli anni 2000, alla fine la digitalizzazione a livello globale e la diffusione di sistemi interconnessi hanno portato il rischio come un fenomeno globale. Le infrastrutture digitali, i mercati finanziari e le reti sono strettamente dipendenti l'una dall'altra e questo porta che un singolo evento si possa propagare velocemente attraverso l'intero sistema, creando effetti a cascata difficilmente prevedibili.

Altra teoria riguardo al modello di rischio

La valutazione e calcolo del rischio rappresentano uno gli aspetti base nella gestione dei sistemi complessi. Questo consiste nell'identificazione, analisi e quantificazione dei fattori che contribuiscono alla generazione di eventi indesiderati.

Il modello che abbiamo visto prima in "Fondamenti teorici della valutazione del rischio" è ampiamente utilizzato in diversi ambiti, tra cui ingegneria, sicurezza sul lavoro, assicurazioni e finanza, grazie alla sua semplicità e accessibilità. Infatti consente di ottenere un primo valore del rischio attraverso la combinazione di due variabili fondamentali.

Tuttavia durante numerosi studi, sono emersi molti limiti riguardo a questa rappresentazione. Nello specifico, come sottolineato da Hubbard, la riduzione del rischio a una semplice moltiplicazione tra probabilità e danno **non è abbastanza sufficiente** per descrivere la complessità dei sistemi reali. Questa visione non tiene conto della variabilità dei contesti, della non coerenza degli effetti e della presenza di eventi estremi.

Nei sistemi di un certo spessore il comportamento del rischio non è sempre lineare. Infatti eventi con probabilità molto bassa possono generare conseguenze enormemente gravi, mentre eventi frequenti possono avere impatti minimi o trascurabili. In questo modo si evidenzia la necessità di modelli più avanzati in grado di rappresentare meglio la realtà.

Proprio per questo, recentemente sono state introdotte ulteriori variabili nella valutazione del rischio, tra cui vulnerabilità ed esposizione.

Estensione del modello: vulnerabilità ed esposizione

Per superare i limiti del modello di base, il rischio viene spesso rappresentato attraverso una formula molto più estesa:

$$R = P \times D \times V \times E$$

dove:

- **V** rappresenta la vulnerabilità del sistema
- **E** rappresenta il livello di esposizione al rischio

La vulnerabilità è la predisposizione di un sistema a subire danni nel momento in cui viene esposto a una minaccia. Questa dipende da molti fattori, tra cui la qualità delle infrastrutture, la flessibilità organizzativa, la preparazione del personale di cui si dispone e la resistenza dei sistemi di sicurezza.

L'esposizione invece rappresenta la probabilità che un sistema venga assalito o colpito da una minaccia. Sistemi sempre connessi o esposti a reti pubbliche presentano molto spesso una esposizione sempre più elevata rispetto a sistemi isolati o ben protetti.

Dopo aver introdotto queste variabili, adesso ci consente una rappresentazione più realistica del rischio, decisamente più utile nei contesti moderni come la cybersicurezza, la gestione delle infrastrutture ad alto rischio e l'analisi dei sistemi.

Modelli multicriterio e approcci ponderati

Un'altra evoluzione della teoria del rischio è rappresentata dai modelli multicriterio, in cui diversi fattori vengono combinati attraverso pesi differenti:

$$R = w_1 \cdot P + w_2 \cdot D + w_3 \cdot V + w_4 \cdot E$$

Questo approccio consente di adattare la valutazione del rischio al contesto specifico di una determinata situazione. Prendiamo un esempio in ambito sanitario, il danno può avere un peso decisamente maggiore rispetto alla probabilità, mentre in ambito informatico la vulnerabilità può essere il fattore principale.

I modelli multicriterio quindi permettono una maggiore flessibilità, ma ci mostrano anche una componente soggettiva legata alla scelta dei pesi e delle soluzioni a tali problemi.

Matrice del rischio

La matrice del rischio è uno degli strumenti più utilizzati nella **pratica**. Questa tabella rappresenta graficamente la relazione tra probabilità e impatto del danno attraverso una griglia.

Sull'asse verticale viene rappresentata la probabilità, mentre sull'asse orizzontale viene rappresentato il danno. Ogni combinazione determina un livello di rischio, generalmente classificato in basso(lieve), medio, alto(grave) o critico(gravissimo).

Questo strumento è decisamente utile perché consente una rappresentazione immediata del rischio anche a soggetti non tecnici. Però presenta limiti legati alla semplificazione e alla soggettività della valutazione.

Altamente probabile	4	8	12	16
Probabile	3	6	9	12
Poco probabile	2	4	6	8
Improbabile	1	2	3	4
P / D	Lieve	Medio	Grave	Gravissimo

Sistemi e risoluzione al rischio emergente

In questo momento storico caratterizzato da una continua e crescente digitalizzazione, con una presente interconnessione dei sistemi, la definizione di rischio non può più essere interpretata attraverso modelli semplici e riduttivi. In modo particolare nelle infrastrutture informatiche, reti distribuite e ambienti digitali, il rischio assume una natura molto presente, derivante non dalla semplice somma di fattori isolati, ma dalla interazione dinamica tra molteplici componenti diverse tra loro.

Un sistema complesso è definito teoricamente come un insieme di elementi interconnessi che interagiscono tra loro attraverso coincidenze non lineari, dando origine a comportamenti di gruppo difficilmente prevedibili partendo dall'analisi delle singole parti. In questo modo il rischio non può essere considerato una variabile statica o limitata in se, ma deve essere interpretato come una proprietà presente nel sistema stesso.

Le caratteristiche fondamentali dei sistemi contribuiscono in modo radicale alla ridefinizione del concetto di rischio.

- **In primo luogo**, la non linearità impone che non esista una proporzionalità diretta tra causa ed effetto, infatti delle variazioni minime durante le condizioni iniziali possono generare conseguenze importanti, rilevanti e a volte sproporzionate. Tutto questo rende i modelli predefiniti, tradizionali, basati su relazioni lineari, molto spesso inadeguati per rappresentare la reale dinamica del rischio.
- **In secondo luogo**, la presenza di feedback introduce una dimensione molto più evoluta. I feedback possono essere positivi potendo gestire al meglio un evento, oppure negativi, contribuendo alla stabilizzazione e evoluzione del sistema. In informatica un attacco iniziale può provocare una serie di reazioni a catena che aumentano di molto il loro attacco o il livello di vulnerabilità, generando un cumulo di tutti questi problemi, che bloccano il sistema.
- **Un terzo luogo** distintivo è rappresentato dall'interdipendenza tra le componenti. Nei sistemi digitali moderni, applicazioni, infrastrutture, database e servizi sono molto integrati. Di conseguenza, un malfunzionamento o una vulnerabilità di una singola componente può propagarsi rapidamente, compromettendo l'intero sistema. Questo infatti è particolarmente evidente nelle architetture cloud e nelle reti distribuite, dove la separazione e distinzione tra livelli logici e fisici è sottile.
- **In quarto luogo** i sistemi complessi sono caratterizzati da una capacità di adattamento costante, ovvero con la possibilità di modificare il proprio comportamento in risposta a presenze esterne. Questo modo di adattarsi se in un certo modo aumenta la flessibilità del sistema, dall'altra parte introduce ulteriori elementi di incertezza, perché le condizioni operative possono cambiare nel tempo in maniera poco prevedibile.

All'interno di questo modello teorico il rischio è decisamente visto in maniera più dinamica e contestuale. Non esiste un valore assoluto di rischio valido in ogni situazione, ma una valutazione che dipende dalle condizioni specifiche del sistema in un determinato momento. Questo porta a superare la visione tradizionale del rischio come prodotto statico tra probabilità e impatto, introducendo una prospettiva più articolata e multidimensionale.

Il cosiddetto di **effetto farfalla**, derivante dalla teoria del caos, rappresenta un esempio molto particolare di questa complessità. Questo principio dice che piccole variazioni nelle condizioni iniziali di un sistema possono determinare esiti completamente differenti nel lungo periodo. In informatica si traduce nella possibilità che una configurazione errata all'inizio apparentemente insignificante si possa evolvere in un problema decisamente critico, se combinata con altre condizioni.

Se notiamo approfonditamente possiamo notare implicazioni rilevanti per la gestione del rischio informatico. Come prima cosa evidenzia i limiti degli approcci deterministici e sottolinea la necessità di adottare modi e soluzioni più flessibili e adattive. Come seconda cosa si introduce il concetto di ambiguità cognitiva, ovvero l'impossibilità di conoscere completamente tutte le variabili e le loro interazioni.

Infatti la gestione del rischio nell'informatica deve essere interpretata non come un processo statico, ma come un ciclo continuo, dinamico e iterativo, in linea con i principali standard internazionali come ISO 31000 e ISO/IEC 27005.

Questo si articola generalmente in quattro fasi principali: **identificazione, analisi, trattamento e monitoraggio** del rischio.

- **La prima fase** consiste nell'identificazione degli asset, ovvero degli elementi che hanno un valore per l'organizzazione, come dati, sistemi, infrastrutture e servizi. Questa fase primaria richiede una comprensione approfondita del contesto operativo e delle dipendenze tra i diversi componenti. Dopo si procede con l'identificazione delle minacce e delle vulnerabilità. Le **minacce** infatti rappresentano la possibilità di eventi dannosi, come attacchi informatici, errori umani o guasti tecnici. Le **vulnerabilità** invece indicano le debolezze del sistema che possono essere sfruttate. In un sistema complesso, la relazione tra minacce e vulnerabilità non è sempre lineare ed è modificata da molteplici fattori.
- **La fase di analisi** del rischio apre alla valutazione della probabilità che una minaccia si concretizzi e dell'impatto che ne potrebbe derivare. Tuttavia come abbiamo già visto, in contesti complessi questa valutazione non può essere considerata assoluta e definitiva, ma deve essere costantemente e continuamente aggiornata in funzione dell'evoluzione del sistema.
- **Il trattamento del rischio** consiste nella scelta di misure pronte a ridurre la probabilità o l'impatto degli eventi negativi. Codeste misure possono includere controlli tecnici come l'aggiunta di sistemi di autenticazione avanzata, la crittografia dei dati e il monitoraggio continuo, oppure controlli organizzativi, come la formazione del personale e la definizione della sicurezza della privacy.
- **Infine, il monitoraggio** continuo rappresenta una fase fondamentale, perché consente di rilevare celermente eventuali cambiamenti del programma di rischio e di adattare le strategie per la gestione. Infatti in un sistema il rischio evolve costantemente, rendendo necessario un approccio attivo e dinamico.

Un aspetto molto rilevante riguarda il fatto che la gestione del rischio informatico non mira all'eliminazione totale del rischio, infatti è un obiettivo spesso irrealistico, ma punta alla sua riduzione a un livello accettabile, in base alle risorse disponibili e degli obiettivi dell'organizzazione. Il nome di questo aspetto è chiamato "risk appetite", rappresenta un elemento chiave nella definizione delle strategie di sicurezza.

La crescente integrazione di tecnologie avanzate, come l'intelligenza artificiale e il machine learning offre nuove opportunità per migliorare la capacità di previsione e risposta ai rischi. Però tali tecnologie introducono anche nuove incertezze, legate alla complessità dei modelli e alla difficoltà di interpretazione dei risultati.

Il rischio nei sistemi informativi e nella cybersecurity

Nel contesto dei sistemi informativi moderni, il rischio ha una dimensione particolarmente critica e strategia nettamente rilevante. L'evoluzione continua della digitalizzazione dei processi organizzativi ha infatti determinato una dipendenza dalle infrastrutture informatiche, rendendo qualsiasi sistema economico, amministrativo o industriale incredibilmente vulnerabile a una vasta quantità di minacce cyber. Per questo la cybersecurity non rappresenta più un ambito puramente tecnico, ma si presenta come una disciplina che coinvolge aspetti tecnologici, organizzativi, economici, giuridici e persino geopolitici.

Il rischio informatico può essere visto come la possibilità che una minaccia, sfruttando una vulnerabilità presente in un sistema informativo, comprometta una o più proprietà fondamentali della sicurezza delle informazioni:

riservatezza, integrità e disponibilità. Infatti questa visione è comunemente nota come **CIA (Confidentiality, Integrity, Availability)** e costituisce uno dei pilastri concettuali della sicurezza informatica moderna.

La **riservatezza** riguarda la protezione delle informazioni da accessi non autorizzati.

L'**integrità** si riferisce alla correttezza e completezza dei dati, garantendo che non vengano alterati in modo non autorizzato.

La **disponibilità**, assicura che i sistemi e le informazioni siano accessibili agli utenti autorizzati quando è necessario.

Le **minacce informatiche** si presentano in modi completamente diversi tra loro e sono in continua evoluzione. Tra le principali categorie si includono malware, phishing, ransomware, attacchi DDoS (Distributed Denial of Service) e data breach. Ognuna di queste tipologie di attacchi agisce secondo modalità differenti e sfrutta specifiche vulnerabilità tecniche o comportamentali.

1. Il **malware**, ad esempio, comprende un software malevolo progettato per compromettere il funzionamento dei sistemi, sottrarre informazioni o ottenere accesso non autorizzato.
2. Il **ransomware** rappresenta una delle forme più gravi di attacco, perché cifra i dati della vittima rendendoli inaccessibili e richiede un riscatto per il loro rilascio.
3. Gli attacchi di **phishing** si basano sull'ingegneria sociale e mirano a ingannare l'utente per ottenere credenziali o informazioni sensibili.
4. Gli attacchi **DDoS** hanno l'obiettivo di rendere un servizio indisponibile sovraccaricando le risorse del sistema attraverso una moltitudine di richieste simultanee provenienti da reti compromesse.
5. **Le violazioni dei dati (data breach)** rappresentano uno degli eventi più critici, perché comportano la compromissione diretta di informazioni sensibili o riservate.

Secondo numerose analisi avviate da grandi big internazionali come IBM Security e Check Point Research, negli ultimi anni si è assistito a un enorme incremento sia quantitativo che qualitativo degli attacchi informatici. Non solo il numero di incidenti è aumentato, ma anche la loro sofisticata tecnica, rendendo sempre più complessa la loro prevenzione e limitazione.

Inoltre tutto questo è amplificato dalla crescente interconnessione dei sistemi digitali e dalla diffusione del cloud che se da un certo punto di vista aumenta l'efficienza operativa, dall'altro espande enormemente la superficie di attacco. Di conseguenza oggi la gestione del rischio informatico richiede un approccio continuo, dinamico e basato sull'analisi predittiva.

Standard internazionali per la gestione del rischio

La gestione del rischio in particolare nell'informatica non è un'attività lasciata alla discrezionalità delle singole organizzazioni, ma è regolata da una serie di standard internazionali che definiscono principi, metodologie e migliori modi di reagire condivise a livello globale.

Tra i principali riferimenti normativi si colloca la norma **ISO 31000**, che presenta linee guida generali per la gestione del rischio in qualsiasi tipo di organizzazione. Questo standard introduce un approccio sistemico e integrato, basato su principi fondamentali come la creazione di valore, l'integrazione nei processi decisionali, il processo di gestione e il miglioramento continuo.

Un altro fondamentale è la **ISO/IEC 27001**, che definisce i requisiti per la creazione e il mantenimento di un Sistema di Gestione della Sicurezza delle Informazioni (ISMS). Questo standard si concentra sulla protezione delle informazioni attraverso l'implementazione di controlli tecnici, organizzativi e procedurali.

Poi c'è la **ISO/IEC 27005**, che si concentra specificamente sulla gestione del rischio informatico. Questa fornisce una metodologia strutturata per l'identificazione, l'analisi, la valutazione e il trattamento dei rischi legati alla sicurezza delle informazioni, facendo particolare attenzione alla relazione tra minacce, vulnerabilità e impatti.

Un altro fondamentale è il **NIST Cybersecurity Framework**, sviluppato dal National Institute of Standards and Technology. Questo framework è generalmente utilizzato a livello internazionale e si basa su cinque funzioni principali: **Identify, Protect, Detect, Respond e Recover**. Queste funzioni rappresentano un ciclo continuo che consente alle organizzazioni di gestire il rischio informatico in modo dinamico e resiliente.

Integrare questi standard all'interno delle organizzazioni consente di avviare un approccio coerente alla gestione del rischio, riducendo la frammentazione delle pratiche e migliorando la capacità di risposta agli incidenti.

Modelli avanzati di valutazione del rischio

L'evoluzione dei sistemi complessi e l'aumento della disponibilità di dati hanno portato allo sviluppo di modelli avanzati di valutazione del rischio, che superano le limitazioni degli approcci tradizionali basati su formule e statistiche semplificate.

Uno di quelli più rilevanti è quello probabilistico esteso dove il rischio non viene rappresentato come un valore definito e determinato, ma come una distribuzione di probabilità. In questo modo il rischio è descritto attraverso scenari multipli, ciascuno associato a una probabilità di occorrenza e a un danno potenziale.

Un approccio particolarmente utilizzato è la **simulazione Monte Carlo**, che consiste nella creazione di un numero elevato di scenari casuali, basati su probabilità e variabili rilevanti. Il processo può essere espresso in quattro fasi principali: **definizione** delle variabili di input, **assegnazione** delle distribuzioni statistiche, **simulazione** iterativa degli scenari e **analisi** della distribuzione dei risultati.

Il principale vantaggio è la capacità di rappresentare non solo il valore medio del rischio, ma anche la sua variabilità e la probabilità di eventi estremi, che nei sistemi complessi rivestono un'importanza molto rilevante.

Machine learning e analisi predittiva del rischio

Come abbiamo detto in precedenza negli ultimi anni l'intelligenza artificiale e il machine learning hanno assunto un ruolo sempre più rilevante nella gestione del rischio, in particolare nel contesto della cybersecurity e dell'analisi dei sistemi complessi.

Attraverso l'analisi di grandi quantità di dati, i modelli di machine learning sono in grado di identificare pattern ricorrenti e costruire predizioni in grado di stimare la probabilità di eventi futuri.

Tra gli algoritmi più utilizzati si presentano anche alberi decisionali, regressione logistica, reti neurali artificiali e tecniche di clustering automatizzato. Questi strumenti consentono di classificare automaticamente il livello di rischio o di prevedere la probabilità di un incidente sulla base di variabili osservate. Nell'informatica infatti, l'analisi dei log di rete, delle configurazioni di sicurezza e dei precedenti incidenti può essere utilizzata per stimare la probabilità di un attacco futuro.

Però l'utilizzo del machine learning introduce anche alcune questioni critiche, come il problema della trasparenza dei modelli (black box problem), la dipendenza dalla qualità dei dati e il rischio di overfitting, che può compromettere le predizioni del sistema in contesti reali.

Governance del rischio nelle organizzazioni e vulnerabilità

La gestione del rischio non può essere considerata un'attività isolata o esclusivamente teorica, ma deve essere integrata all'interno della governance complessiva dell'organizzazione. Questa visione totale del rischio definisce infatti ruoli, responsabilità e processi decisionali relativi alla gestione delle minacce e delle vulnerabilità. Un sistema efficace di governance esprime l'identificazione degli asset critici, la valutazione periodica dei rischi, la definizione delle soglie di accettazione, l'implementazione di controlli previsti e il monitoraggio continuo della sicurezza. Un importante concetto come nominato precedentemente in questo ambito è il Risk Appetite, ovvero il livello di rischio che un'organizzazione è disposta ad accettare per raggiungere i propri obiettivi strategici. Questo elemento varia significativamente in base al settore, alla dimensione e alla natura dell'organizzazione.

Nelle applicazioni web uno dei riferimenti più importanti per l'analisi del rischio è rappresentato dall'**OWASP Top 10**, che identifica le principali vulnerabilità delle applicazioni web a livello globale. Tra le vulnerabilità più critiche si includono SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Broken Authentication e Security Misconfiguration. Queste vulnerabilità sono punti di ingresso privilegiati per gli attaccanti ed una delle principali fonti di rischio nei sistemi digitali.

L'analisi delle vulnerabilità OWASP è fondamentale nei processi di risk assessment, perché permette di identificare i punti deboli del sistema prima che possano essere sfruttati da soggetti malevoli.

Limiti dei modelli tradizionali di rischio

Nonostante la loro enorme diffusione i modelli tradizionali di valutazione del rischio presentano diversi limiti.

- **Il primo** limite riguarda la **soggettività delle valutazioni**, ovvero che la probabilità e l'impatto vengono spesso stimati qualitativamente, introducendo un margine di incertezza significativo.
- **Il secondo** limite è la **semplificazione eccessiva della realtà**. Ridurre il rischio a una formula matematica lineare non permette di cogliere le dinamiche non lineari tipiche dei sistemi complessi.

- **Il terzo limite** è la **staticità dei modelli tradizionali**, che non riescono a rappresentare in modo adeguato la natura dinamica del rischio, che però deve evolvere continuamente nel tempo in parallelo a nuove minacce, vulnerabilità emergenti e cambiamenti ambientali.

Per questo motivo i modelli più avanzati tendono a integrare approcci probabilistici, simulativi e basati su intelligenza artificiale, con l'obiettivo di rappresentare il rischio in modo più realistico e adattivo.

Sistema pratico digitale per la gestione del rischio

La traduzione dei modelli teorici di rischio in strumenti operativi e pratici richiede la progettazione di sistemi digitali in grado di supportare l'utente nella valutazione, interpretazione e gestione delle informazioni in modo strutturato e affidabile. Per questo un software dedicato alla gestione del rischio non può essere ridotto a una semplice implementazione di formule matematiche, ma deve essere concepito come un vero e proprio sistema di supporto alle decisioni (Decision Support System, DSS), capace di integrare dati, modelli e interfacce. L'obiettivo principale di questi sistemi è quello di trasformare concetti complessi, spesso astratti e teorici, in strumenti operativi comprensibili anche da utenti non specialisti. Questo implica la necessità di una forte transizione tra complessità teorica e semplicità d'uso comune, attraverso l'adozione di interfacce guidate e processi strutturati.

Un sistema moderno per la gestione del rischio si basa molto spesso su un'architettura multilivello, genericamente suddivisa in tre componenti principali: **frontend**, **backend** e **database**. Questa struttura permette di separare in modo più chiaro le responsabilità funzionali del sistema, migliorando scalabilità, manutenibilità e sicurezza.

- Il frontend rappresenta il livello di interazione con l'utente e ha il compito di raccogliere input, visualizzare risultati e guidare il processo decisionale.
- Il backend gestisce invece la logica applicativa, i modelli di calcolo e l'elaborazione dei dati.
- il database è responsabile della memorizzazione costante delle informazioni relative ad asset, minacce, vulnerabilità e scenari di rischio.

In modo più tecnico il **frontend** di un sistema di gestione del rischio è spesso sviluppato utilizzando tecnologie web standard come HTML5, CSS3 e JavaScript, spesso supportate da framework moderni come React, Angular o Vue.js. L'uso di questi strumenti permette di realizzare interfacce dinamiche, reattive e compatibili con diversi dispositivi, inclusi desktop, tablet e smartphone (dispositivi mobili).

Un elemento fondamentale del frontend è la progettazione dell'interazione utente-sistema. Il concetto di rischio è inevitabilmente complesso, l'interfaccia deve essere progettata per ridurre il carico di difficoltà e guidare l'utente attraverso un percorso logico e ben strutturato. Questo si ottiene attraverso wizard, form guidati e visualizzazioni grafiche semplici da capire.

Il **backend** costituisce il cuore logico del sistema, perché può essere implementato attraverso tecnologie come Node.js, Python, Django, Flask o Java Spring Boot, in base alle esigenze di scalabilità e performance. Il suo compito principale è quello di elaborare i dati inseriti dall'utente, applicare i modelli matematici e restituire risultati interpretati. All'interno del backend vengono utilizzati anche i modelli di valutazione del rischio, le logiche decisionali e le eventuali integrazioni con sistemi esterni. Inoltre, il backend gestisce anche aspetti critici come autenticazione, autorizzazione e sicurezza delle comunicazioni.

Il **database** rappresenta il livello di persistenza del sistema. In base alla natura dei dati, è possibile utilizzare database relazionali (chiamati SQL) o non relazionali (chiamati NoSQL). I database SQL sono preferibili quando non ci si può permettere errori o incongruenze nei dati mentre si fanno modifiche, mentre i database NoSQL, come MongoDB, risultano più versatili alla gestione di dati semi-strutturati e dinamici. L'intero sistema ovviamente deve essere progettato secondo principi fondamentali di ingegneria del software, tra cui modularità, scalabilità, resilienza e sicurezza by design.

Esperienza utente e accessibilità

Un aspetto importantissimo nella progettazione di sistemi di gestione del rischio è rappresentato dall'esperienza utente (User Experience), che ha decisamente un ruolo cruciale nel garantire l'efficacia operativa e decisionale del sistema. Il rischio è un concetto complesso, multidimensionale, incerto e interdipendente tra le variabili. Per questo all'interno di un sistema digitale deve essere attentamente progettato in modo da rendere comprensibili informazioni complesse.

L'interfaccia utente non può essere considerata semplicemente qualcosa di estetico, ma deve svolgere una funzione di cognizione e funzionale, agendo come ponte tra la complessità teorica del rischio e l'applicazione pratica. Qui la

User Experience diventa uno strumento di traduzione della complessità teorica, capace di aiutare l'utente nella comprensione dei dati e nel processo decisionale.

Un User Experience efficace deve guidare l'utente attraverso un percorso logico e ben strutturato, che rifletta le fasi fondamentali della gestione del rischio. Questo include l'**identificazione** degli asset, la **definizione** delle minacce, la **valutazione** dei parametri (probabilità, impatto, vulnerabilità, esposizione) e la **visualizzazione** dei risultati. La sequenza di queste fasi non è casuale, ma viene dalla struttura teorica dei modelli di risk assessment, e contribuisce a ridurre problemi di comprensione interpretativa.

La User Experience si fonda su principi consolidati, come:

- La **coerenza visiva**, che porta l'utente a sviluppare un modello mentale stabile del sistema.
- Il **feedback** immediato, che riduce l'incertezza operativa.
- La **riduzione del carico mentale e intellettuale**, ottenuta attraverso la semplificazione e la gerarchizzazione delle informazioni.
- La **chiarezza espositiva**, che permette di distinguere tra dati essenziali e informazioni marginali.
- Un ruolo fondamentale è svolto sicuramente dagli **strumenti di visualizzazione**. L'utilizzo di matrici, indicatori cromatici e dashboard interattive consente di trasformare dati complessi in rappresentazioni intuitive. Le matrici del rischio facilitano la classificazione immediata dei livelli di pericolosità, mentre le dashboard permettono una visione sintetica e integrata nel sistema.
- L'**accessibilità** rappresenta un requisito indispensabile. Un sistema moderno deve essere progettato per essere utilizzabile da tutti gli utenti, incluse persone con disabilità sensoriali, motorie o cognitive. Ciò implica il rispetto delle linee guida WCAG (Web Content Accessibility Guidelines), che spiegano vari standard internazionali per la progettazione inclusiva. Tra questi principi di accessibilità si includono la percepibilità delle informazioni (contrasti adeguati e testi alternativi), la navigabilità tramite tastiera, la compatibilità con tecnologie assistive e la leggibilità dei contenuti. L'accessibilità non è soltanto una questione tecnica o normativa, ma è un elemento fondamentale di qualità e inclusiva del sistema.

Integrazione con standard e sistemi esterni

Un sistema digitale di gestione del rischio non può operare in modo isolato, ma deve essere integrato all'interno di un arcipelago di standard normativi e sistemi informativi. Questo è fondamentale per garantire coerenza di metodo, aggiornamento continuo e affidabilità delle valutazioni.

L'allineamento con standard internazionali come abbiamo già approfondito in precedenza, rappresenta il primo livello di integrazione. Con norme secondo ISO 31000 forniscono un quadro generale per la gestione del rischio, definendo principi e linee guida applicabili in qualsiasi contesto. Allo stesso tempo ISO/IEC 27001 stabilisce i requisiti per la sicurezza delle informazioni, mentre ISO/IEC 27005 si centralizza specificamente sulla gestione del rischio informatico. Il NIST Cybersecurity Framework rappresenta un ulteriore riferimento fondamentale, grazie a un ciclo continuo articolato in cinque funzioni: Identify, Protect, Detect, Respond e Recover. Questo modello consente di integrare la gestione del rischio all'interno di un processo dinamico e adattivo.

Oltre agli standard, un ruolo cruciale è svolto dall'integrazione con **sistemi tecnologici avanzati**. I sistemi **SIEM** (Security Information and Event Management) permettono di raccogliere e analizzare eventi di sicurezza in tempo reale, dando dati aggiornati e contestualizzati per valutare il rischio.

Oltre a questi ci sono i sistemi **GRC** (Governance, Risk and Compliance) che consentono di integrare la gestione del rischio con la governance aziendale e le normative, creando un approccio unico e coerente.

Un altro livello di integrazione è dedicato i database di vulnerabilità, come **CVE** e **NVD**. Questi forniscono informazioni aggiornate sulle vulnerabilità già note, permettendo di migliorare la precisione delle valutazioni e di ridurre i tempi di risposta agli incidenti.

Applicazione pratica della gestione del rischio

Per capire come rendere applicabili i modelli teorici, è importante analizzare un caso concreto relativo a un'organizzazione che gestisce infrastrutture IT critiche.

1. L'organizzazione identifica **tre asset principali**: un database clienti, un server applicativo e un sistema di backup. Ogni asset viene analizzato in termini di valore, criticità e potenziali minacce, tra cui attacchi informatici, errori umani e guasti hardware.
2. Attraverso un **sistema digitale** di gestione del rischio, vengono assegnati valori quantitativi e qualitativi alle variabili rilevanti: probabilità, impatto, vulnerabilità ed esposizione. Il sistema elabora questi dati utilizzando modelli matematici e restituisce una spiegazione sintetica del rischio, molto spesso sotto forma di matrice.

3. L'**analisi** evidenzia che il database clienti rappresenta l'asset più critico, a causa delle elevate informazioni contenute e della maggiore esposizione a minacce esterne. Questa valutazione consente all'organizzazione di definire priorità di intervento e posizionare risorse in modo efficiente.
4. Le **misure di mitigazione** includono crittografia dei dati, autenticazione multi fattore e segmentazione della rete.

Questo caso dimostra come la gestione del rischio rappresenti uno strumento essenziale, capace di aiutare a prendere decisioni concrete e migliorare la sicurezza complessiva del sistema.

Etica e responsabilità nella gestione del rischio

La gestione del rischio non può essere considerata soltanto sotto il profilo tecnico, ma deve includere anche un'etica e una morale sociale. Le decisioni su un'analisi del rischio possono infatti avere conseguenze significative su individui, organizzazioni e comunità.

Importante è il principio della **trasparenza**. Gli utenti devono comprendere almeno in maniera generale i criteri utilizzati per la valutazione del rischio e le logiche decisionali del sistema. Questo è nettamente importante nei sistemi automatizzati, dove il rischio di fraintendimento è elevato.

Importante è anche la **responsabilità**. I sistemi digitali infatti devono essere progettati come strumenti di aiuto nelle decisioni e non come sostituti dell'umano. La responsabilità finale delle decisioni deve rimanere sempre agli operatori in capo. Particolare focus e concentrazione ci vuole con il problema dei **bias algoritmici**. Questi sono basati su dati incompleti o distorti possono generare valutazioni inaccurate o prediligendo dati errati, che possono portare a gravi conseguenze. Per questo è necessario adottare approcci **trasparenti** e **controllabili**.

Evoluzione futura dei sistemi di gestione del rischio

Il futuro è strettamente legato allo sviluppo dell'intelligenza artificiale, machine learning e analisi predittiva. I sistemi di nuova generazione saranno preparati per analizzare grandi volumi di dati in tempo reale, identificare pattern complessi e aggiornare dinamicamente le valutazioni del rischio. Questo porterà a un passaggio da modelli statici a sistemi adattivi e auto apprendenti. Si prevede che in prossimo futuro ci sarà una crescente integrazione tra sistemi di sicurezza, business e governance aziendale, con la creazione di digitali ecosistemi interconnessi.

Tuttavia anche con tutta questa automatizzazione il ruolo **umano rimarrà centrale**, soprattutto nelle decisioni strategiche e nell'interpretazione dei risultati. Una delle evoluzioni più rilevanti nella teoria del rischio è il passaggio da una visione statica a una visione dinamica e continua. Il rischio non può essere considerato un valore fisso, ma deve essere monitorato costantemente nel tempo. Questo piccolo ma fondamentale passaggio implica l'adozione costante di un ciclo continuo composto da identificazione, analisi, trattamento, monitoraggio e revisione.

Conclusione

Arrivati alla fine di questo elaborato il rischio appare sotto una visione diversa rispetto a come viene comunemente pensato. Non è più soltanto qualcosa da evitare o ridurre, ma come una componente inevitabile dei sistemi complessi e in un certo senso come una chiave di lettura della realtà contemporanea.

Viviamo in un periodo storico in cui ogni scelta, tecnologica o organizzativa, comporta una percentuale di incertezza e questa incertezza non può essere eliminata, ma può essere compresa, interpretata e gestita.

Proprio in questo passaggio dalla paura dell'imprevedibile alla sua analisi strutturata che si colloca il valore della gestione del rischio. Ciò che esce è che non esiste un modello perfetto o universale. Ogni approccio, per quanto sofisticato, rappresenta sempre una semplificazione della realtà. Ma allo stesso tempo queste semplificazioni non sono un limite da eliminare, ma uno strumento fondamentale per rendere l'incertezza affrontabile. La vera differenza non sta tanto nei modelli utilizzati, ma nella capacità di interpretarli e adattarli al proprio contesto.

Nel mondo digitale questa consapevolezza diventa ancora più rilevante. La velocità con cui evolvono le tecnologie e le minacce, rende il rischio qualcosa di dinamico, celere e mai statico. Non si tratta di raggiungere uno stato di "sicurezza assoluta", perché non sarà mai possibile raggiungere la perfezione, ma bisogna mantenere un equilibrio continuo tra protezione, funzionalità e innovazione. In questo modo la gestione del rischio diventa un processo vivente, che richiede aggiornamento costante e capacità di adattamento.

Un aspetto particolarmente significativo riguarda il ruolo umano, perché anche in presenza di strumenti avanzati, modelli quantitativi e tecnologie predittive, la decisione finale resta sempre una **responsabilità delle persone**. Il rischio come abbiamo visto, non è solo un dato numerico, ma una valutazione che coinvolge delle priorità, valori e

obiettivi. Questo rende la gestione del rischio non solo una disciplina tecnica banale e superflua, ma anche un'attività profondamente decisionale e interpretativa.

Allo stesso tempo bisogna avere una visione condivisa, perché quando il rischio viene espresso attraverso linguaggi chiari e strutturati, diventa più facile comunicarlo, discuterlo e integrarlo nei processi decisionali. In questa maniera non rimane confinato a un ambito specialistico, ma diventa parte della cultura organizzativa e quotidiana.

Guardando avanti nel futuro è evidente che il ruolo del rischio continuerà a crescere. L'espansione dei sistemi digitali, l'evoluzione dell'intelligenza artificiale e l'aumento delle interdipendenze globali renderà tutto questo ancora più complesso e imprevedibile. La capacità di gestire il rischio rappresenterà sempre più un fattore distintivo, non solo in termini di sicurezza, ma anche di competitività tra organizzazioni e sostenibilità. Volendo concludere vediamo che il rischio non è qualcosa da eliminare, ma da comprendere. Accettarne la presenza significa riconoscere i limiti della nostra previsione allo stesso tempo non bisogna avere paura, ma valorizzare gli strumenti che permettono di prendere decisioni più consapevoli. È proprio questa tensione tra incertezza e controllo che si crea una gestione del rischio efficace, capace di trasformare un punto di debolezza in un elemento di forza.

APPLICAZIONE WEB

1. Struttura iniziale. Il frammento di codice definisce la parte fondamentale del documento seguendo lo standard HTML5. L'istruzione `<!DOCTYPE html>` e l'attributo `lang="it"` garantiscono la corretta interpretazione dal browser. È fondamentale la presenza del tag `"viewport" content="width=device-width, initial-scale=1.0"`, che abilita la responsività, garantendo alla pagina di adattare automaticamente le proprie dimensioni alla larghezza dello schermo del dispositivo mobile usato

```
1
2 <!-- Inizio del progetto html con codici utilizzo per pc e dispositivi mobili -->
3 <!DOCTYPE html>
4 <html lang="it">
5 <head>
6   <meta charset="UTF-8">
7   <meta name="viewport" content="width=device-width, initial-scale=1.0">
8   <title>Fattore di rischio e Cybershield</title>
9
```

2. Collegamento dei fogli. Questa riga di codice utilizza il tag `<link>` per collegare un foglio di stile esterno denominato `"style.css"`. Questa scelta permette di separare nettamente il contenuto (HTML) dalla presentazione (CSS), facilitando la comprensione e manutenzione del software, assicurando che lo stile sia coerente in tutte le sezioni dell'applicativo.

```
<!-- dila css esterno "style.css" -->
<link rel="stylesheet" href="style.css">
```

3. Configurazione dell'ambiente grafico. Il codice applica lo stile all'elemento `body`, ovvero l'intera area visibile della pagina. Viene impostato il colore blu e utilizzata la **Flexbox** per centrare perfettamente il contenuto principale al centro dello schermo. Il font di base è impostato su **Arial** o sans-serif per garantire massima leggibilità.

```
2 /* Sfondo*/
3 body {
4   margin: 0;
5   font-family: Arial, sans-serif;
6   background: #0079b3;
7   display: flex;
8   justify-content: center;
9   padding: 20px;
10 }
11
```

4. Design del contenitore principale. Viene stilizzata la classe **.container**, che fa da "scheda" centrale. Il codice definisce una larghezza massima, un colore di sfondo chiaro (color crema) e angoli arrotondati (**border-radius: 15px;**). L'aggiunta di una **box-shadow** conferisce profondità, mentre il selettore **p** applica una specifica tonalità di colore marrone ai paragrafi per mantenere l'identità visiva del brand.

```
/* Quadrato principale di base */
.container {
  background: #f9f9f9;
  width: 100%;
  max-width: 500px;
  padding: 30px;
  border-radius: 15px;
  text-align: center;
  box-shadow: 0 4px 15px #ccc;
}

h1 {
  margin-bottom: 10px;
}

/* frasi piccole */

p {
  color: #a4783b;
}
```

5. Architettura semantica dei contenuti. Struttura del corpo centrale della pagina organizzata in sezioni semantiche. La testata (**header**) contiene il titolo principale, mentre la sezione **download-card** presenta il link diretto al documento PDF sul calcolo del fattore di rischio su GitHub. È presente anche la sezione dedicata al **QR Code**, fondamentale per l'accesso rapido da smartphone.

```
<body>

  <main class="container">

    <header>
      <h1>Risk Assessment Tool</h1>
      <p>Come calcolare il fattore di rischio</p>
    </header>

    <!-- Download per PDF -->
    <section class="download-card">
      <h2>Documento PDF</h2>
      <p>Scarica la guida completa per il calcolo del rischio</p>

      <a href="https://micaeltuscano-source.github.io/PW--valutazione-rischio/guida-fattore-rischio.pdf"
        class="btn-download"
        download>
        Scarica PDF
      </a>
    </section>

    <!-- QR code per il download del PDF -->
    <section class="qr-section">
      <h3>QR Code per download rapido</h3>
      <p>Scansiona il codice per accedere al file</p>

      <div id="qrcode"></div>
    </section>

  </main>
```

6. Stilizzazione del pulsante di download. Il codice definisce **.btn-download**. Il pulsante è configurato come un elemento **inline-block** con un colore di sfondo arancione e testo bianco.

```
34
35  /* Tasto per scaricare il PDF*/
36
37  .btn-download {
38    display: inline-block;
39    margin-top: 20px;
40    padding: 15px 25px;
41    background: #cb934e;
42    color: white;
43    text-decoration: none;
44    border-radius: 6px;
45    font-weight: bold;
46  }
47
```

7. Logica del QR Code. Questo script di JavaScript gestisce l'integrazione col QR Code. Attende che il documento sia completamente caricato **DOMContentLoaded** e utilizza la libreria **QRCode** per generare un codice di **180x180 pixel**. Il codice punta direttamente all'URL del PDF, permettendo all'utente di inquadrare lo schermo del PC con il proprio cellulare e scaricare istantaneamente la guida.

```
</main>

<!-- codice per il QR code -->
<script>
  document.addEventListener("DOMContentLoaded", function () {

    const pdfLink = "https://michaeluscano-source.github.io/PW--valutazione-rischio/guida-fattore-rischio.pdf";

    new QRCode(document.getElementById("qrcode"), {
      text: pdfLink,
      width: 180,
      height: 180,
      colorDark: "#2c3e50",
      colorLight: "#ffffff",
      correctLevel: QRCode.CorrectLevel.H
    });

  });
</script>

</body>
</html>
```

8. Ottimizzazione mobile e rifiniture CSS. L'uso delle **Media Queries** (**@media**) modificano lo stile della pagina quando viene visualizzata su schermi piccoli (sotto i 600 pixel). In questo caso, viene rimosso l'effetto ombra e ridotto il padding del container per massimizzare lo spazio utile. Poi viene definito un bordo solido per l'immagine del QR Code per farla risaltare sullo sfondo.

```
49  /* QR code margini e immagine */
50
51  #qrcode {
52    margin-top: 20px;
53  }
54
55
56  #qrcode img {
57    border: 5px solid #rgb(255, 253, 253);
58    outline: 1px solid #fffefe;
59  }
60
61
62
63  @media (max-width: 600px) {
64    .container {
65      padding: 15px;
66      box-shadow: none;
67    }
68
69
70
71
72    .btn-download {
73      display: inline-block;
74      padding: 15px 25px;
75      background: #cb934e;
76      color: white;
77      text-decoration: none;
78      border-radius: 6px;
79      font-weight: bold;
80      max-width: 250px;
81      width: 100%;
82    }
83  }
```

Campi di applicazione

(Descrivere gli ambiti di applicazione dell'elaborato progettuale e i vantaggi derivanti della sua applicazione):

L'elaborato ha molti contesti di applicazione caratterizzati dalla necessità di analizzare, comprendere e gestire il rischio in sistemi complessi, in particolare nel campo della sicurezza informatica e della gestione dei sistemi digitali. Il principale ambito di applicazione è rappresentato dalle organizzazioni aziendali, sia pubbliche che private, dove la gestione del rischio costituisce un elemento fondamentale per garantire la continuità operativa e la protezione degli asset. In contesti come questi i modelli teorici e le metodologie descritte precedentemente viste consentono di aiutare

i processi di decisione, per migliorare la capacità di individuare vulnerabilità, minacce e apportare strategie di mitigazione utili e efficaci.

Molto importante è quello della cybersecurity, dove l'aumento della complessità delle infrastrutture digitali e delle minacce rende indispensabile un approccio strutturato alla gestione del rischio. Le tecniche analizzate permettono di affrontare scenari dinamici e legati tra loro, contribuendo alla protezione di dati sensibili, sistemi critici e servizi digitali.

Il progetto è applicabile anche nel campo della gestione delle infrastrutture tecnologiche, incluse reti e sistemi cloud, dove la varietà tra componenti richiede una valutazione continua del rischio. La capacità di interpretare il rischio come fenomeno molto presente consente di migliorare la flessibilità dei sistemi e di prevenire effetti a catena derivanti da singoli problemi.

Poi l'applicazione è presente nella governance e nella normativa, in cui le organizzazioni devono conformarsi a standard e framework internazionali. L'approccio descritto supporta l'allineamento con tali normative, facilitando la strutturazione di processi di gestione del rischio coerenti e documentabili.

Il vantaggio primario invece è prima di tutto una maggiore consapevolezza del rischio, trasformando l'incertezza in informazione utile per il processo decisionale. Poi permette una riduzione della probabilità e del danno degli eventi negativi, attraverso misure preventive e scelte adeguate.

Un beneficio è poi rappresentato dalla standardizzazione dei processi di valutazione, che favorisce coerenza, trasparenza e comunicazione tra i diversi attori coinvolti. Questo risulta particolarmente importante in contesti organizzativi complessi, dove il rischio deve essere condiviso e compreso a diversi livelli gerarchici. Alla fine un'altra cosa importante da considerare è la resistenza come capacità di resistere, adattarsi e recuperare dopo a eventi negativi. In un periodo storico caratterizzato da cambiamenti continui e crescente incertezza, questa capacità rappresenta un elemento strategico e fondamentale per la sostenibilità e la competitività nel lungo periodo.

Valutazione dei risultati

(Descrivere le potenzialità e i limiti ai quali i risultati dell'elaborato sono potenzialmente esposti):

I risultati del progetto evidenziano come un approccio strutturato alla gestione del rischio consente di migliorare di molto la capacità di analisi e interpretazione dell'incertezza nei sistemi complessi.

Le metodologie che sono state presentate offrono strumenti utili per rappresentare il rischio in modo sistematico, favorendo maggiore consapevolezza nei processi decisionali.

Tra le principali potenzialità si regge la capacità di formalizzare il rischio, trasformando un concetto spesso astratto e teorico in un elemento analizzabile e confrontabile. Questo aiuta a prendere decisioni più consapevoli riducendo le valutazioni soggettive. L'elaborato dimostra e aiuta a comprendere meglio tutte le caratteristiche sulla gestione del rischio, dando la possibilità di formazione e ricerca riguardo all'argomento in questione.

Purtroppo questo progetto evidenzia anche alcuni limiti significativi: in primis la presenza di una componente soggettiva, in quanto nessun testo è completamente soggettivo, perché l'autore di un testo immedesima sempre una parte di se stesso in quello che sta scrivendo. Questo aspetto è particolarmente rilevante quando si ricercano diverse argomentazioni e temi probabilmente paralleli, che non sono tuttavia citati in queste pagine. Essendo purtroppo un argomento molto frammentato e in continua evoluzione, toccare tutti i punti del tema sarebbe impossibile.

Tuttavia questo limite non rappresenta una criticità per le basi e le radici riguardo al rischio.

Un altro limite riguarda la semplificazione dei modelli che, seppur necessaria per rendere il rischio analizzabile, può non captare pienamente la complessità delle interazioni nei sistemi reali. In particolare, non viene trattato ogni incognita nello specifico in maniera approfondita, tutto a causa della mole di variazioni e strumenti impossibili da elencare. La dinamicità del rischio informatico rappresenta una sfida costante e non ci è possibile spiegare quello che il futuro ci riserverà. Perciò questo l'elaborato si è dedicato all'idea radice e base dell'argomento.

Nonostante questo, il concetto principe è stato individuato e strutturato, partendo dalle origini storiche fino ai giorni nostri, evidenziandone il suo valore per la cultura, l'informazione e lo studio.